

Digital Ecosystems Architecture and the DIB Compliance Stack

Why Compliance Is the Governing Layer, and Architecture Is How an Enterprise Satisfies It Coherently

Author: James D. Longmire

Working Paper, Application Layer. Companion to Digital Ecosystems Architecture: A Three-Baseline Framework for Coherent Digital Realization and to Digital Ecosystems Architecture and the Unified Architecture Framework.

Epistemic status: Positioning argument. The broad structure of the DIB compliance regime is anchored to primary DoD, NIST, and CNSS sources at HIGH confidence as of May 2026: the CMMC program rule (32 CFR Part 170) effective 16 December 2024, the acquisition rule (48 CFR) effective 10 November 2025, and DoD Class Deviation 2024-00013 holding NIST SP 800-171 Revision 2 as the assessed baseline until rescinded. The one materially contingent claim is the Phase 2 transition dated 10 November 2026, which is future-dated relative to this paper and identified as such rather than asserted as settled. Compliance dates and clause status move; this paper should be re-verified against the controlling instruments before any external release.

Summary

Compliance is the governing layer over a defense enterprise. The Cybersecurity Maturity Model Certification program, the underlying NIST control catalogs, the export-control regime, and, on the classified side, the accreditation and continuous-monitoring requirements that gate an Authorization to Operate are not constraints the architecture may weigh against other concerns. They are the conditions under which the enterprise is permitted to operate at all. An architecture framework that positioned itself above these obligations would invert the actual authority relationship and would deserve the skepticism it received.

Digital Ecosystems Architecture does not sit above compliance and does not govern it. It sits beneath the governing layer and serves it. The contribution is specific and bounded. DEA supplies no controls, no authority, and no certification; every obligation originates entirely outside the framework. What DEA supplies is the structure through which an enterprise demonstrates that those externally imposed obligations actually hold across the capability, technical, and operational tiers, and hold consistently across the boundary between the unclassified and classified domains, rather than fragmenting into per-domain, per-assessment paperwork that drifts from the architecture it is supposed to describe.

The argument is the mirror image of the companion paper on the Unified Architecture Framework. There, DEA earned a position *above* UAF on the governance axis and acknowledged a dependency *below* it on the description axis. Here the altitude is reversed and the honesty is the same. Compliance sits above DEA on the

obligation axis; DEA serves it on the coherence axis. The relationship is service, not rivalry and not supersession, and stating it precisely is what keeps the positioning credible rather than grandiose.

Positioning formula

Compliance sets the obligation and the gate; DEA makes satisfaction traceable, owned, and durable.

The governing layer tells the enterprise what must be true and verifies it at the gate; the architecture is how the enterprise stays true between the gates and across the boundary.

1. Compliance Governs; The Question Is Whether It Coheres

A defense enterprise does not choose its compliance obligations the way it chooses an architecture pattern. The obligations arrive as binding instruments. On the unclassified side a contract clause imposes a safeguarding requirement and a certification gate stands between the enterprise and award. On the classified side an accreditation regime stands between a system and the permission to run. In both cases the authority is external, the consequence of failure is exclusion from the mission, and the architecture is subject to the obligation rather than the other way around. This is the first thing a positioning argument must concede plainly, because any framing that treats compliance as one architectural concern among several has already misread the power structure of the environment it claims to serve.

The failure that actually occurs in this environment is not absence of controls. Defense organizations have system security plans, plans of action and milestones, control-implementation matrices, and binders of evidence. The failure is that the compliance artifact and the operating architecture drift apart. A security plan asserts a boundary the technical realization does not match. A control attests that protected information is encrypted along a path the running solution does not actually take. An export determination scopes a capability, and a later supplier change moves data across the boundary the determination assumed, while every individual control remains green on its own line. Each obligation is satisfied on paper. The enterprise still fails, because the failure is in the joins.

That sentence is deliberate. The base layer of this framework opens on exactly that diagnosis: competent work in each discipline that does not add up, an enterprise that accumulates artifacts while becoming less coherent. The compliance domain is not a new application of the framework. It is the original problem wearing a regulator's seal. The controls are new vocabulary; the coherence failure is the one DEA was built to address. So the governing question DEA asks of compliance is not whether the controls exist. The governing layer already requires them and assesses them. The question DEA asks is whether each obligation can be traced from the requirement that imposes it, through the capability that owns it, the technical structure that realizes it, and the operation that exercises it, to the evidence that it holds, and whether that trace survives the crossing into the classified domain. Where the trace holds, the enterprise can show compliance in fact. Where it breaks, the enterprise has compliance on paper and is one assessment away from discovering the difference.

2. The Governing Layer, On Its Own Terms

A fair positioning argument states what the governing layer is before claiming any relationship to it. The DIB compliance stack is best understood not as one regime but as a class of obligations that enter the enterprise through distinct mechanisms and, critically, through two different security domains. This paper does not

recapitulate the controls. It characterizes the structure, because the structure is what the architecture has to hold together.

2.1 The unclassified domain: authority by contract clause

For controlled unclassified information, the obligation enters by contract. The Defense Federal Acquisition Regulation Supplement safeguarding clause has imposed the protection of covered defense information for years, and the Cybersecurity Maturity Model Certification program now stands as the verification gate on top of it. The program rule that establishes CMMC took effect in December 2024, and the acquisition rule that lets contracting officers place CMMC requirements into solicitations took effect in November 2025; the phased rollout that began with the latter moves from self-attestation toward mandatory third-party certification for most contracts involving controlled unclassified information. Level 2 of the program corresponds to the full set of requirements in the established NIST control baseline for such information; the higher level adds selected enhanced requirements for the most sensitive material.

One status detail must be stated precisely rather than from memory, because it is counterintuitive and easy to get wrong. A newer revision of the NIST control baseline has been finalized and published, yet it is not the assessed standard. A standing Department of Defense class deviation holds the prior revision as the baseline against which scores are calculated and certifications are assessed, and that deviation carries no defined expiration. The practical consequence for an architecture is that the obligation is stable and known today, while a revision transition is visible on the horizon and is the kind of future-dated change that should be tracked as a constraint rather than assumed.

2.2 The classified domain: authority by accreditation

For classified information, whether collateral, special-access, or sensitive-compartmented, the obligation does not enter by a contract clause an officer inserts into a solicitation. It enters by accreditation. A system is categorized, a control baseline drawn from the federal catalog and the national-security overlay is selected and tailored, implementation guidance specific to the program type is applied, and an Authorizing Official renders a risk-based decision that grants or withholds permission to operate. The authorization is not permanent. It is sustained by continuous monitoring, and the running system's security state is tracked against the controls for the life of the authorization.

At the highest level the classified domain shares one abstract obligation with the unclassified: protect the information entrusted to the enterprise. Below that abstraction the regimes are not the same. The classified domain carries distinct legal, policy, programmatic, and operational obligations, and it imposes them through an entirely different authority mechanism and an entirely different evidence regime. The unclassified path produces a score and a certificate; the classified path produces an authorization decision and a monitoring record. A capability that is straightforward to realize and evidence in the unclassified domain may have constrained realization in the classified domain, where platform options are narrower, authorization cycles are longer, and some collaboration and cloud capabilities are available only in limited form. That constraint is a property of the governing regime and the threat environment. It is a leadership decision about acceptable risk, not a deficiency in the architecture that operates under it, and the distinction matters because mislabeling a binding constraint as an execution failure misdirects both accountability and remedy.

2.3 Obligations that ride alongside both

Two further obligation classes cut across the domain boundary rather than belonging to one side. Export control governs the technical data and defense articles the enterprise handles regardless of classification, and it turns certain access and transfer questions into legal determinations about persons and destinations. Supply-chain obligations flow the safeguarding and certification requirements down to subcontractors and partners, which means the enterprise is accountable not only for its own posture but for the coherence of an ecosystem of suppliers whose changes can move its risk without notice. Both classes are reasons the architecture has to reason laterally and not only vertically, a point Section 4 develops.

3. Why The Governing Layer Needs An Architecture Beneath It

The governing layer requires coherence but does not, by itself, produce it. A certification program defines what must be true and how it will be assessed. An accreditation regime defines how permission to operate is granted and sustained. Neither tells the enterprise how to keep the obligation aligned with the architecture as the architecture changes, and neither is accountable when the security plan and the running system part ways between assessments. That gap is precisely where DEA's existing commitments do load-bearing work, and none of it has to be invented for the compliance case because the framework already argues for all of it.

3.1 Traceability is how an obligation is governed, not merely recorded

The framework's central claim is that traceability is the mechanism of governance rather than after-the-fact documentation. Applied to compliance the claim sharpens. A control that cannot be traced from the obligation that imposes it, through the capability and technical realization, to operational evidence that it holds, is not a documented-but-unverified control. In the framework's terms it is ungoverned, because the governance function has no basis on which to decide whether it is real. This reframes the gap between the security plan and the operating reality, the gap that actually fails assessments and surfaces in findings, as a traceability break, which the framework already has the apparatus to name and locate. The certificate attests a point in time. The trace is what makes the attestation continuously checkable rather than a snapshot the enterprise hopes still holds.

3.2 Operational readiness includes staying compliant after the assessment

The framework holds that operational readiness is an architectural concern set as a constraint upstream and satisfied downstream, not discovered after delivery. Compliance is among the clearest cases. Both domains now demand more than a point-in-time posture: the unclassified regime requires a senior affirming official to attest annually, in the government's supplier-performance system, that the organization has implemented and will maintain the applicable security requirements, and the classified regime sustains an authorization only through ongoing monitoring. The annual attestation is not a formality. It is a recurring legal certification submitted as a condition of contract eligibility, and a false or reckless affirmation carries liability under the False Claims Act. Compliance that is achieved at assessment and decays afterward is therefore not merely an architectural untidiness; it is the post-delivery-readiness failure the framework already names, now with a signature and a statute attached. Whether a solution can remain monitorable, reportable, and re-authorizable is decided when the capability is scoped and its technical realization chosen, long before an assessor or an

Authorizing Official looks at it. To treat continued compliance as someone's downstream problem is to make an architectural decision and decline to be accountable for it.

3.3 Entitlement is the object where the boundary is actually enforced

The framework names entitlement as a cross-tier object with two facets: authorization to access, the right to reach a resource, and authority to act, the right to take action against it. Decided in the technical baseline where access models and identity structures are designed, exercised in the operational baseline under live conditions. This object is where the compliance argument and the framework's forthcoming AI extension share a spine, and it is the strongest single hook for the compliance case. Access control is the access facet. The enforcement of a classification boundary, the determination of who and what may cross it, is an entitlement question in exactly the framework's sense: set in the technical baseline, exercised operationally, and accountable across both. As systems begin to act with some autonomy, the authority-to-act facet becomes a live compliance concern rather than a settled one, because an agent's runtime permissions are simultaneously a control-design decision and an operational reality. The framework already carries the object the compliance regime needs in order to locate where its boundary is genuinely enforced rather than merely declared.

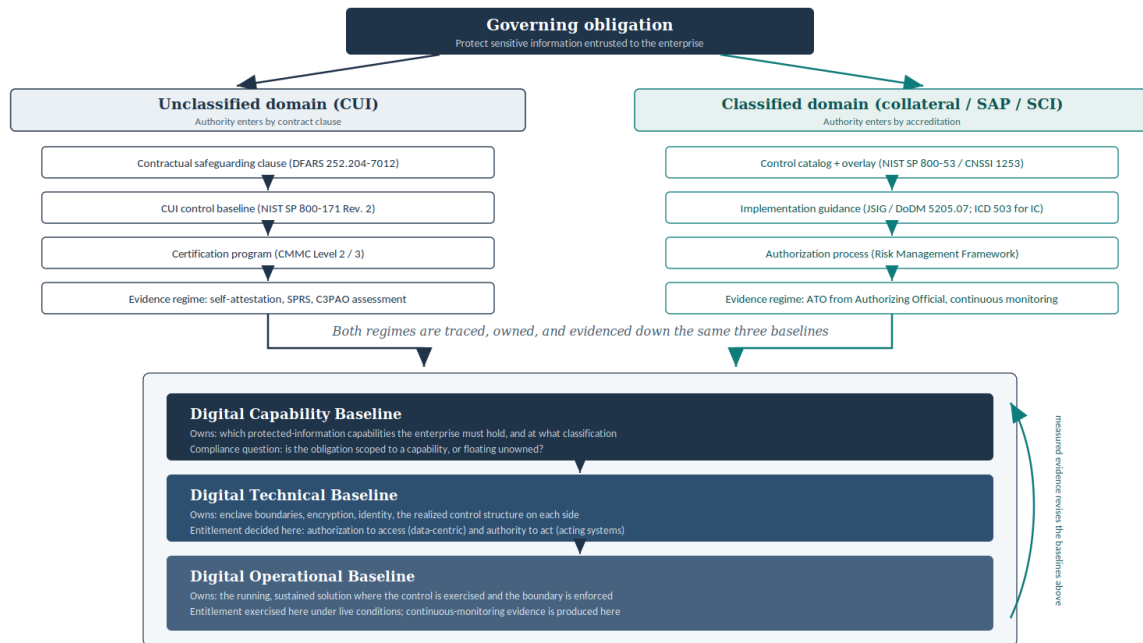
4. The Structural Argument: One Obligation, Two Authority Paths, One Spine

The clearest evidence that DEA serves the governing layer rather than duplicating it is what happens when the same obligation is followed through both security domains at once. The obligation is singular: protect the information entrusted to the enterprise. The authority mechanisms are not. The unclassified path runs through a contract clause, a control baseline, a certification program, and an attestation-and-assessment evidence regime. The classified path runs through a control catalog and overlay, program-specific implementation guidance, a formal authorization process, and an evidence regime built on an Authorizing Official's decision and continuous monitoring. These are genuinely different regimes. They diverge by design.

What the architecture contributes is the convergence. Both paths are traced, owned, and evidenced down the same three baselines, and they meet at the same cross-tier entitlement object where each domain's boundary is enforced. That shared spine is the contribution, and it is falsifiable in the way a positioning claim should be. If the two paths ran down separate architectural structures, the enterprise would be holding two disconnected compliance stories that drift apart precisely at the boundary where drift is least tolerable. The single spine is what prevents that. The figure below makes the divergence and the convergence visible together.

The Same Obligation, Two Authority Paths, One Architecture

DIB compliance enters the enterprise through two regimes and is evidenced down a single shared baseline spine.



What the figure proves

The two columns are genuinely different regimes: different authority, different evidence. They diverge by design, not by accident. The convergence onto one baseline spine is what the architecture contributes: a single traceability and accountability structure across the classified boundary. Were the two paths to run down separate spines, the enterprise would hold two disconnected compliance stories, and the coherence claim would be false.

Confidence: HIGH on regime structure and authority mechanisms (primary DoD/NIST sources). Obligation classes shown, not control identifiers, by design. Classified-domain capability is constrained, not absent.

Figure 1. The same governing obligation entering through two authority paths and converging on a single baseline spine. Obligation classes and authority mechanisms are shown rather than control identifiers, by design; reducing the framework to a control matrix would repeat the error the base layer rejected when it declined to force the framework's relationships into a generic modeling association.

Read the figure as an argument rather than an illustration. The two columns are not a comparison offered for interest. They are two regimes the enterprise must satisfy simultaneously and consistently, and the claim that DEA holds them as one architecture is true only if they share the spine the figure shows them sharing. The lateral arrow on the right, evidence rising to revise the baselines above, is the closed loop the base layer insists on: a monitoring finding in the operational baseline is not merely a compliance ticket, it is information that should revise the technical and capability baselines that allowed the gap. An architecture that records the finding and changes nothing upstream has reduced its own feedback loop to documentation, which is the failure the framework was built to refuse.

5. The Lateral Failures Compliance Misses

Vertical traceability is necessary and not sufficient. The framework is named for ecosystems because digitally realized capabilities fail sideways as well as downward, and the compliance domain supplies some of the clearest lateral failures in any enterprise. A supplier change alters the risk posture of multiple authorized solutions at once. A shared identity pattern becomes the hidden coupling that lets an entitlement decision made for one enclave silently affect another. A control introduced to satisfy one domain's overlay becomes

friction or, worse, exposure in another. A data product assembled for an unclassified purpose becomes a dependency for a system whose obligations its original sponsors never considered. None of these is a broken vertical trace. Each is an ecological failure, arising from interaction and dependency across the environment.

This is why supply-chain compliance and the flow-down of safeguarding and certification obligations to subcontractors cannot be governed as a stack of independent vertical traces. The enterprise is accountable for the coherence of an ecosystem it does not fully control. The framework's lateral-dependency frame is the part of the governance structure that keeps second-order consequence in view, and it is the part most often missing when compliance is treated as a per-system certification exercise. A defensible compliance posture for a defense enterprise is not the sum of its authorized systems. It is the coherence of the environment those systems, their suppliers, their shared data, and their operators jointly form.

6. Service, Not Supersession

The move that keeps this argument honest is the same one the companion paper made, inverted. Having said that the architecture serves the governing layer, the paper must state with equal clarity how completely the architecture depends on that layer, because a framework that quietly claimed to improve on compliance would be making exactly the empty gesture it warns against.

DEA contributes no controls. It defines no safeguarding requirement, sets no certification threshold, draws no control baseline, and grants no authorization. Every obligation, every assessed requirement, every authority mechanism originates entirely in the governing layer and would exist in full force if the framework did not. The architecture cannot relax an obligation, cannot substitute its own judgment for an Authorizing Official's, and cannot treat a coherence argument as a reason to weaken a security boundary. On the obligation axis the subordination is total, and it should be, because the alternative is an architecture that reasons its way around a binding constraint, which in this environment is not a clever outcome but a disqualifying one.

What the architecture contributes is bounded to the coherence axis. It makes the difference between compliance on paper and compliance in fact an architectural property the enterprise can govern: traced from obligation to evidence, owned across tiers, sustained after the assessment, and held consistent across the classified boundary rather than fragmented into parallel paperwork that drifts. Stated as plainly as the argument allows: the governing layer tells the enterprise what must be true and verifies it at the gate; the architecture is how the enterprise stays true between the gates and across the boundary. Neither substitutes for the other. A perfectly compliant set of system security plans describing an incoherent enterprise is achievable and dangerous. A coherent architecture that ignored its obligations would never be permitted to operate. The two are complementary by construction, and the layering runs in one direction: compliance above, architecture beneath, traceability binding them.

7. Practical Use

For a defense enterprise that already carries the full weight of the compliance regime, the division of labor reduces to a single operating rule: the governing layer sets the obligation and the gate; the architecture makes satisfaction traceable, owned, and durable across both domains. A governance review does not ask whether the controls exist, since the regime already requires them. It asks whether each obligation traces from

requirement to operational evidence, whether a single accountable owner answers for it across the capability, technical, and operational tiers, whether continued compliance was set as an upstream constraint rather than left to discover after delivery, and whether the trace holds when the capability crosses into the classified domain. Where the answer is yes, the enterprise can demonstrate compliance in fact and is ready for the assessment rather than bracing for it. Where the answer is no, the enterprise has found a governance gap before an assessor or an adversary does.

This is the same governing question the base layer poses, asked in the one domain where the cost of an unanswered trace is measured in lost authorizations and excluded contracts rather than in abstract incoherence. The architecture does not make the enterprise compliant. The governing layer defines what compliance is and the enterprise's own work achieves it. The architecture is what makes that achievement coherent, evidenced, and durable rather than a binder assembled in time for an assessment and quietly false the week after.

8. Conclusion

DIB compliance is the governing layer over a defense enterprise, binding across the unclassified and classified domains through different authority mechanisms and different evidence regimes. Digital Ecosystems Architecture does not govern that layer and does not sit above it. It serves the layer by supplying the one thing the regime requires but does not itself produce: a single traceability and accountability structure through which externally imposed obligations are shown to hold across the capability, technical, and operational tiers, and across the boundary between the two security domains, rather than fragmenting into per-domain paperwork that drifts from the architecture it describes.

The evidence for the relationship is structural, not rhetorical. The same obligation enters through two genuinely different paths and converges on one baseline spine. A framework that merely duplicated the compliance regime would show one path; a framework that sat above the regime would claim to redraw it. DEA does neither. It carries both paths down a shared spine and meets them at the entitlement object where each domain's boundary is enforced. The convergence is the contribution and the divergence is the proof that the contribution is needed. Compliance names what must be true and verifies it; the architecture is how an enterprise keeps it true, coherently, on both sides of the line.

References

- Committee on National Security Systems (2022) *CNSSI No. 1253, Categorization and Control Selection for National Security Systems*, 29 July 2022 (superseding the 27 March 2014 edition). Fort Meade, MD: CNSS. The companion document to NIST SP 800-53 governing categorization and control selection, including national-security overlays, for classified and other national security systems. Confidence HIGH; cited from the primary CNSS instruction.
- Department of Defense (2016) *Joint Special Access Program (SAP) Implementation Guide (JSIG)*. Technical supplement to NIST SP 800-53 and CNSSI 1253, applied with DoDM 5205.07 in the Risk Management Framework. Defense Counterintelligence and Security Agency. Available at: <https://www.dcsa.mil>

Department of Defense (2024) *Class Deviation 2024-00013, Revision 1, Safeguarding Covered Defense Information and Cyber Incident Reporting*, issued 2 May 2024. Directs contracting officers to require compliance with NIST SP 800-171 Revision 2 under DFARS 252.204-7012 in lieu of the version in effect at solicitation. The deviation states that it remains in effect until rescinded. Confidence HIGH; the deviation number, effect, and until-rescinded status are confirmed from the primary DoD class-deviation compilation (current through January 2026).

Department of Defense (2024) *Cybersecurity Maturity Model Certification (CMMC) Program, 32 CFR Part 170*. Final rule published at 89 FR 83092 on 15 October 2024, effective 16 December 2024. Establishes CMMC policy, maturity levels, assessment parameters, the annual affirmation requirement (32 CFR 170.22), and subcontractor flow-down (32 CFR 170.23). The program incorporates NIST SP 800-171 Revision 2 by reference as the Level 2 baseline.

Department of Defense (2025) *CMMC Acquisition Rule, 48 CFR (DFARS Case 2019-D041)*, effective 10 November 2025. Authorizes inclusion of CMMC requirements in solicitations and contracts and revises DFARS clause 252.204-7021. Phase 2, beginning 10 November 2026 per 32 CFR 170.3(e), is the point at which third-party Level 2 certification becomes the default for contracts involving controlled unclassified information. The Phase 2 date is future-dated relative to this paper and flagged accordingly.

Director of National Intelligence (2008, amended 2015) *Intelligence Community Directive 503, Intelligence Community Information Technology Systems Security Risk Management*. Establishes IC risk management, security authorization and assessment, reciprocity, and interconnection guidelines aligned to the NIST Risk Management Framework.

National Institute of Standards and Technology (2020, updated 2021) *NIST Special Publication 800-171 Revision 2, Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations*. Gaithersburg, MD: NIST. The 110-requirement baseline currently assessed under CMMC Level 2.

National Institute of Standards and Technology (2024) *NIST Special Publication 800-171 Revision 3*. Gaithersburg, MD: NIST. Finalized and published; not the assessed DoD baseline as of this paper, pending formal adoption. Cited for forward context only.

National Institute of Standards and Technology (2020) *NIST Special Publication 800-53 Revision 5, Security and Privacy Controls for Information Systems and Organizations*, and *NIST Special Publication 800-37 Revision 2, Risk Management Framework for Information Systems and Organizations*. Gaithersburg, MD: NIST. The control catalog and authorization process underlying classified-domain accreditation.

Longmire, J.D. (2025) *Digital Ecosystems Architecture: A Three-Baseline Framework for Coherent Digital Realization*. Working Paper, Conceptual Base Layer.

Longmire, J.D. (2025) *Digital Ecosystems Architecture and the Unified Architecture Framework*. Working Paper, Application Layer.

Figure 2. Synthesis Exhibit

A one-page synthesis of the argument developed across this paper, for executive reference. The structural proof of the positioning, the divergence of the two authority paths and their convergence on a single baseline spine, is carried by Figure 1 in Section 4; this exhibit recapitulates the whole and should be read after it, not in place of it. Confidence and verification qualifications stated in the body, in particular the future-dated Phase 2 transition, apply here as well.

